Cloud Security

Yuvaraj K
2022506079

Agenda

1. Cloud Security Risks and Countermeasures
2. NIST Guidelines on Security
3. Database Environments
4. Cloud SecaaS
5. Security Controls

Introduction

- Security controls in cloud similar to any IT environment.
- Cloud Computing may present some specific risks.
- Enterprise loses control over resources, services, applications.
- Must maintain accountability for security and privacy policies.

Top Cloud-Specific Security Threats and Countermeasures

by Cloud Security Alliance [CSA10]

Threat	Countermeasures
Abuse and nefarious use of cloud computing • Easy to register and use cloud services • Free limited trial periods • Attackers can get inside the cloud and conduct attacks	• Stricter initial registration and validation • Enhanced credit card fraud monitoring and coordination • Comprehensive introspection of customer network traffic • Monitoring public blacklists for one's own network blocks
Insecure interfaces and APIs • APIs for authentication, access control, encryption, etc. • Must be designed to protect against accidental and malicious attempts to circumvent policy	• Analyzing security model of CP interfaces • Implementation of strong authentication and access control • Understanding dependency chain associated with APIs
Malicious insiders • Direct control over many aspects of security relinquished • Unprecedented level of trust to CP	• Enforce strict supply chain management • Conduct comprehensive supplier assessment • Specify human resource requirements in legal contract • Require transparency in information security practices • Determine security breach notification processes

Threat	Countermeasures
Shared technology issues • IaaS vendors deliver services in a scalable way • Infrastructure (CPU caches, GPUs) shared • Not designed to offer strong isolation properties • Isolated virtual machines – vulnerable to attack	• Security best practices for installation/configuration • Monitor environment for unauthorized changes/activity • Promote strong authentication and access control • Enforce SLAs for patching, vulnerability remediation
Data Loss or Leakage	• Encrypt and protect integrity of data in transit • Analyze data protection at design and run time • Implement strong key generation, storage, destruction
Account or service hijacking • Usually with stolen credentials • Attacks access critical areas of deployed services	• Prohibit sharing of account credentials • Leverage strong 2FA • Proactive monitoring to detect unauthorized activity
Unknown risk profile • Client cedes control to CP on a number of security issues • Must clearly define roles and responsibilities	• Disclosure of applicable logs and data • Partial/full disclosure of infrastructure details • Monitoring and alerting on necessary information

Compromising Data

- Deletion/alteration of records that have no backup
- Unlinking a record from a larger context
- Storage on unreliable media
- Loss of an encoding key
- Unauthorized parties gaining access to sensitive data

NIST Guidelines on Security

Governance	Extend policies, procedures, standards used for application development and service provisioning in the cloud.
Compliance	Understand laws and regulations that impose security and privacy obligations in the organization.
Trust	Ensure that service arrangements allow visibility into security and privacy controls and processes employed by CP.
Architecture	Understand underlying technologies that the CP uses to provision services.

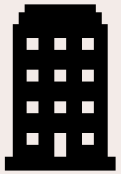
NIST Guidelines on Security

IAM	Adequate safeguards to secure authentication, authorization, and other IAM functions.
S/W Isolation	Understand virtualization and other logical isolation techniques employed.
Data Protection	Evaluate ability to control access to data, and secure data while at rest, in transit, in use, and to sanitize data.
Availability	Understand provisions and procedures for availability, data backup and recovery, disaster backup and recovery.
Incident Response	Understand provisions for incident response.

Database Environments

Multi-Instance Model

- Unique DBMS running on a VM for each cloud subscriber.
- Gives subscriber complete control over role definition, user authorization, etc.



Multi-Tenant Model

- Predefined environment for the cloud subscriber.
- Shared with other tenants, typically through tagging data with subscriber ID.

Securing Data in DB

Data must be secured at rest, in transit, in use, and access must be controlled.

Ideal → client encrypts DB, stores in cloud, CP has no access to encryption key.

Inflexible, as user has to download entire tables from DB and decrypt them even to access individual data items.

More flexibility needed → must be possible to work with DB in encrypted form.

Possible Approach

Simplest and straightforward approach. Consists of 4 different entities.

Data Owner: Organization that produces data to be made available for controlled release.

User: Human entity that queries the DB.

Client: Frontend → transforms user queries to encrypted queries.

Server: Organization that receives encrypted data from data owner, makes them available for clients.

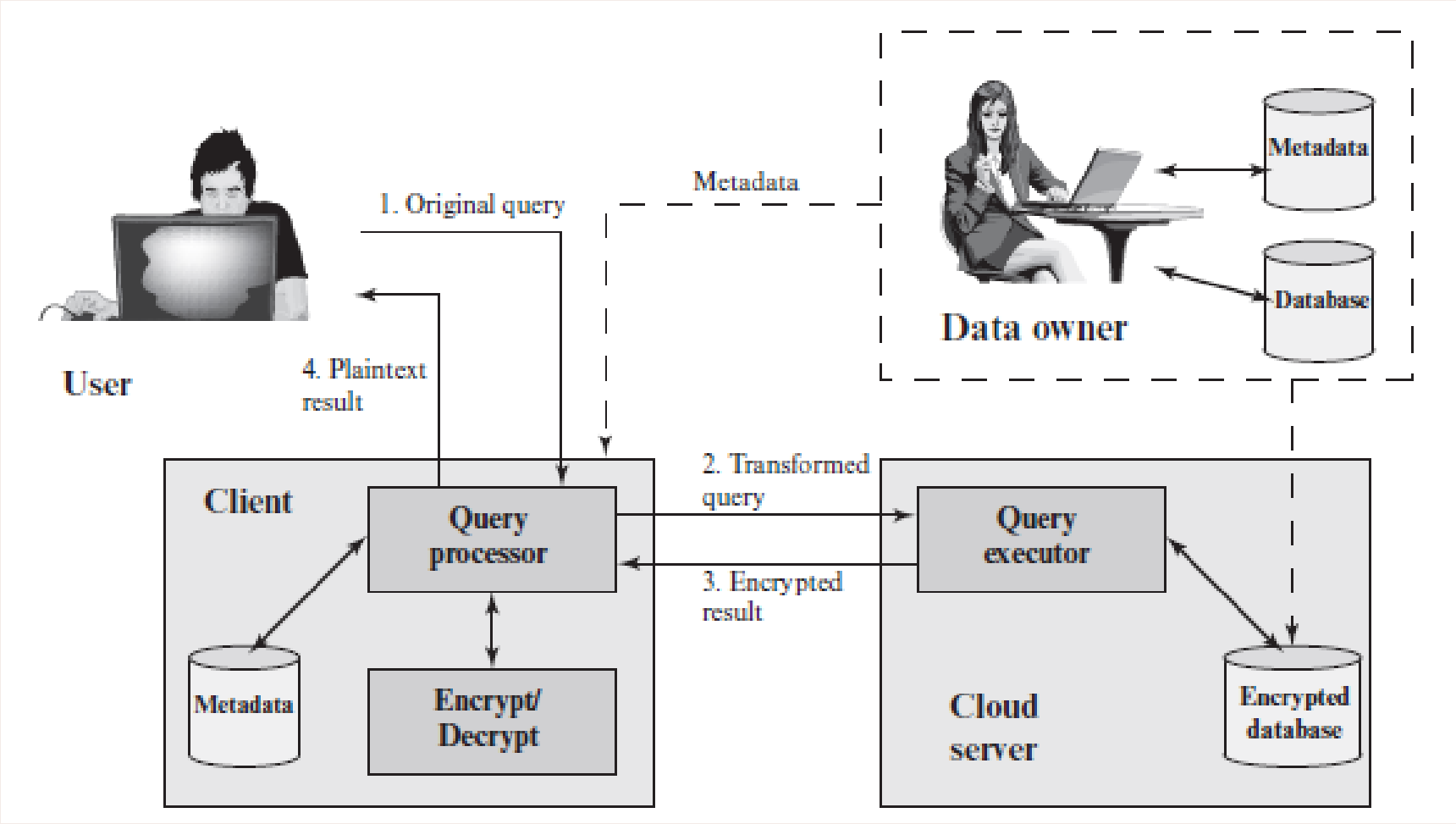
Workflow

User queries for fields with specific primary key PK.

Client encrypts PK, modifies query, sends to server.

Server, processes encrypted query and returns records.

Client decrypts data and returns the results to user.



“

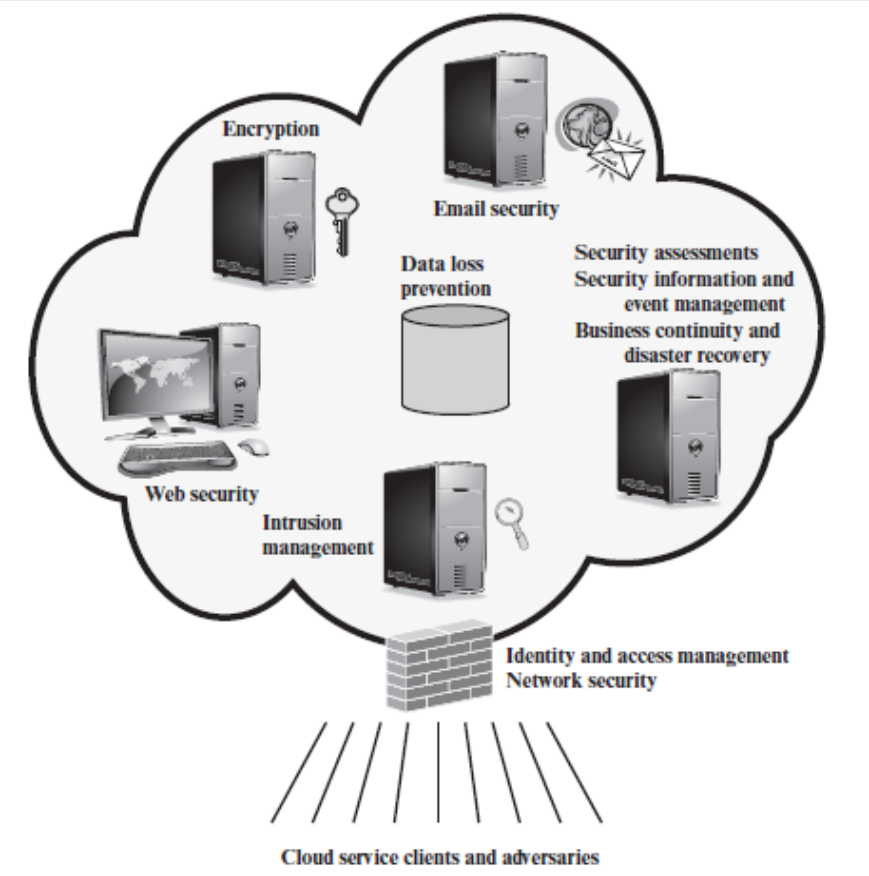
Provision of security applications and services via the cloud, either to cloud-based infrastructure and software or from the cloud to the customers’ on-premise systems.

Cloud Security as a Service – Cloud SecaaS

”

Elements of Cloud SecaaS

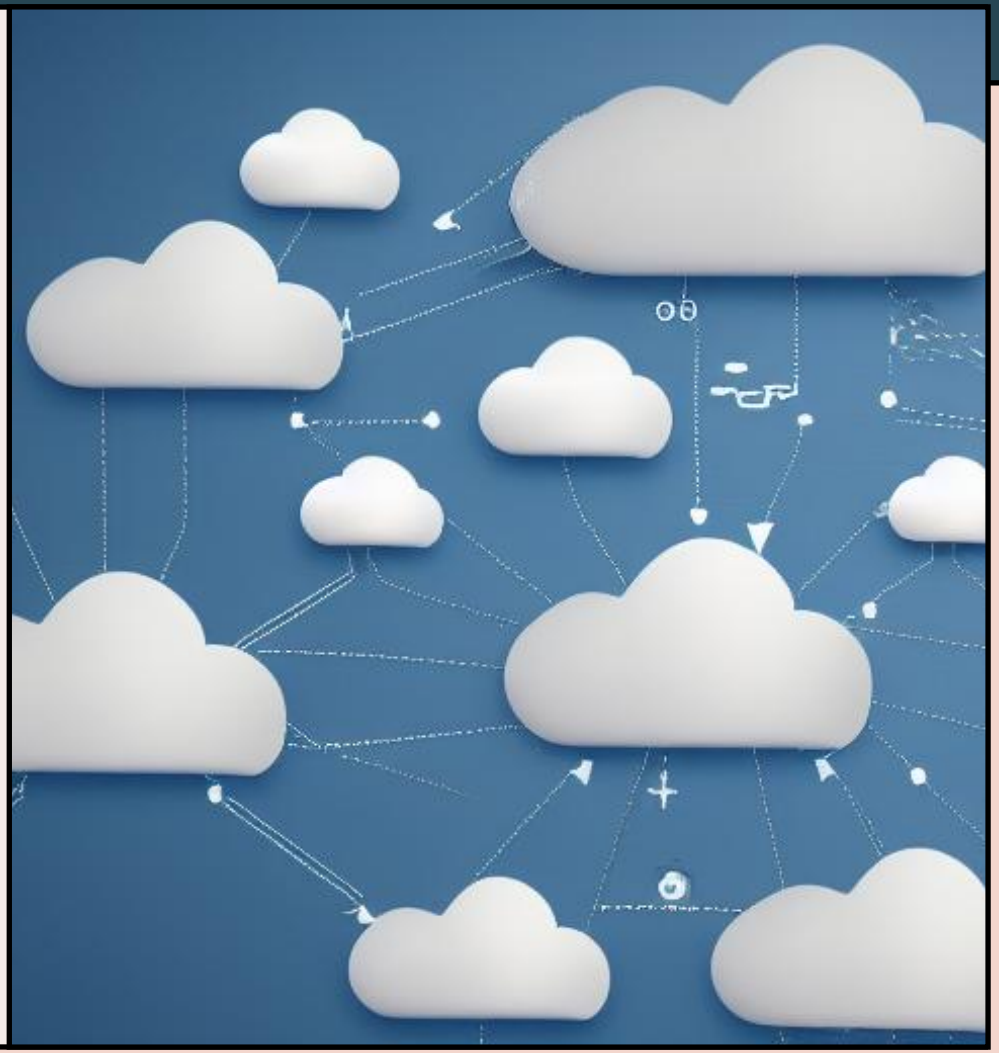
IAM	Data Loss Prevention
Web Security	Email Security
Security Assessments	Intrusion Management
Security Information and Event Management	Encryption
Business Continuity and Disaster Recovery	Network Security



Security Controls

Technical	Operational	Management
Access Control	Awareness and Training	Certification and Accreditation
Audit and Accountability	Configuration and Management	Security Assessment
Identification and Authentication	Contingency Planning	Planning Risk Assessment
System and Communication Protection	Incident Response	System and Services Acquisition
	Maintenance	
	Media Protection	
	Physical and Environmental Protection	
	Personnel Security System	
	Information Integrity	

Thank You

Yuvaraj K

2022506079